SECURITY

ELEVATED

ROGUE DEPENDENCY

A popular open source package your product depends on was silently compromised in its latest release. The malicious version has been downloaded millions of times across the industry. Half your stack may be affected.

Software supply chain attacks have become one of the fastest-growing threat vectors — the SolarWinds and XZ Utils incidents demonstrated how deeply a single compromised package can penetrate enterprise infrastructure. The DevOps response requires a Software Bill of Materials (SBOM) — a complete inventory of every dependency and its version — so you can query instantly whether you are affected. Automated dependency scanning tools (Dependabot, Snyk, OWASP Dependency-Check) should run in every CI pipeline. Pinning dependency versions and verifying checksums prevents silent upgrades to malicious releases. This is a textbook 'shift-left security' practice.

Supply chain attacks are now a top threat vector. You can't audit what you don't track.

TEAM DISCUSSION

Do you have a software bill of materials (SBOM)? Are dependencies locked and scanned automatically in CI?